

Executive Summary — Audit Keamanan SecureBank API

Q3

Ringkasan Eksekutif untuk Manajemen

Chief Information Security Officer (Draft)

7 Agustus 2026

Executive Summary — Audit Keamanan SecureBank API

Pesan Utama untuk Manajemen

SecureBank API telah melalui **audit keamanan menyeluruh** yang mencakup seluruh siklus pengembangan sampai infrastruktur cloud. Hasilnya: **risiko keamanan aplikasi saat ini MEDIUM dan terkendali** — seluruh temuan **Critical telah ditutup**, pipeline keamanan berjalan otomatis di setiap rilis, dan tidak ada kerentanan yang mengancam data nasabah secara langsung dalam kondisi saat ini.

Poin Kunci

Aspek	Kondisi Saat Ini
Postur risiko	MEDIUM — terkendali, tanpa temuan kritis tersisa
Temuan aktif	6 (1 High, 2 Medium, 2 Low, 1 Info) dari 52 temuan historis
Pemicu utama tersisa	1 kerentanan High pada komponen aplikasi (perlu rebuild image)
Pipeline keamanan	7 lapis scan otomatis, seluruhnya hijau di CI/CD
Dampak finansial	Belum ada insiden; kontrol pencegahan & deteksi telah bekerja

Apa yang Berhasil Dicapai Sepanjang Periode

Program keamanan dibangun berlapis (defense-in-depth) dan membuktikan hasilnya dengan **angka sebelum & sesudah**:

- **Melindungi data nasabah**: penggantian hashing password lemah (MD5) dengan kriptografi modern (bcrypt) dan perbaikan celah injeksi database — menghilangkan 2 risiko tinggi yang berpotensi bocornya data.
- **Mengamankan infrastruktur cloud**: bucket penyimpanan (S3) yang sebelumnya dapat diakses publik kini dikunci + ter-enkripsi, dan firewall (Security Group) terbuka diperketat — kegagalan pada standar CIS AWS turun dari **132 → 106 item**.
- **Mengeraskan lingkungan Kubernetes**: 16 konfigurasi tidak aman (kontainer berjalan sebagai root/privileged tanpa batasan resource) dikurangi menjadi **0**.

- **Membangun lapisan pertahanan aktif:** kebijakan admission control, deteksi runtime, dan alerting real-time terhubung ke Slack — termasuk simulasi serangan (red teaming) yang membuktikan kontrol berhijau.

Risiko yang Masih Perlu Perhatian

Kami transparan soal 3 hal yang belum tuntas dan membutuhkan keputusan:

1. **Perbarui image aplikasi (HIGH).** Versi base image menggunakan Go lawas yang mengandung kerentanan. Solusinya mudah: rebuild dengan versi terbaru. **Rencana: sebelum rilis production berikutnya.**
2. **Komunikasi via HTTPS (MEDIUM).** Endpoint belum berjalan di atas TLS. **Rencana: implementasi Q3.**
3. **WAF & pemulihan node lab (Q4).** Perlindungan aplikasi dengan Web Application Firewall dan pemulihan node lab dijadwalkan Q4.

Fokus Rencana ke Depan

- **Q3:** perbarui image aplikasi (tutup temuan HIGH) + aktifkan HTTPS.
- **Q4:** implementasi Web Application Firewall (WAF) dan otomatisasi sinkronisasi dashboard temuan agar data tidak basi.

Kesimpulan

Investasi keamanan yang dilakukan berhasil menurunkan profil risiko secara material: dari kondisi awal penuh temuan kritis menjadi **postur yang terjaga dengan 1 temuan High yang solusinya sederhana**. Dengan dua langkah segera (rebuild image & HTTPS), posisi keamanan SecureBank API dapat ditingkatkan ke **LOW**. Tidak ada rekomendasi yang membutuhkan kerja besar sebelum jangka waktu berikutnya.

Dokumen ini merupakan ringkasan eksekutif dari audit lengkap di laporan-audit-q3.md (Laporan Audit Keamanan Q3, 7 halaman).